

# Методология проверки безопасности

## CommitScope 2.4.0 / Сначала область проверки

Проверяйте точный неизменяемый коммит Git по политике, утвержденной вне целевого репозитория. Зафиксируйте активы, нарушителей, границы доверия, поддерживаемые языки, манифесты зависимостей, исключения и проверяемые инварианты безопасности. Отсутствие покрытия не означает отсутствие проблем.

Код, комментарии, настройки проекта, вывод сканеров и моделей являются недоверенными материалами. CommitScope не собирает и не исполняет целевой проект. Воспроизведение требует отдельного разрешения и изолированной среды.

## Один локальный процесс

Подготовьте чистое рабочее дерево и полный идентификатор коммита в нижнем регистре. Запустите `commitscope review` с утвержденной политикой, точным ID модели, входом через аккаунт, явным согласием на передачу кода и новым защищенным каталогом вне целевого проекта.

Процесс экспортирует снимок коммита и запускает Semgrep, Gitleaks, Trivy, независимый Claude Hunter и новый Claude Verifier. Для завершения корпоративной проверки обязательны сканеры, Hunter и Verifier. Отчеты CI и команды совместимости дают только частичные материалы.

## Разделяйте поиск и опровержение

Hunter предлагает гипотезы, привязанные к коммиту и политике. Verifier независимо проверяет гипотезы и требуемое покрытие. Для существенной находки свяжите управляемый ввод, достижимый путь, нарушенный инвариант, существующую защиту, последствия и сильнейший контраргумент.

Утверждение модели не является доказательством. Проверяйте материалы и уверенность, сохраняйте отвергнутые гипотезы и фиксируйте неопределенность. Сбой входа, квоты, модели, тайм-аута, формата ответа или покрытия приводит к INCOMPLETE.

## Три результата, затем решение человека

READY\_FOR\_HUMAN\_REVIEW (код 0): этапы завершены, нормализованных находок на пороге политики нет. FINDINGS\_REQUIRE\_TRIAGE (код 1): этапы завершены, находки достигают порога. INCOMPLETE (код 2): не выполнена предпосылка или обязательная проверка.

READY\_FOR\_HUMAN\_REVIEW не разрешает слияние и не утверждает, что приложение безопасно.

# Сохранить, проверить, решить

## Защитите исходные материалы

Весь каталог запуска конфиденциален. Храните его без изменений в защищенном хранилище компании. Нормализованные отчеты верхнего уровня и evidence/ можно передавать только по правилам компании. Не публикуйте и не коммитьте сырой вывод сканеров, пакеты исходников, ответы моделей и диагностику из private/.

Внешняя политика проверяется до запуска сканеров и создания артефактов: распознаваемые значения авторизации Bearer/Basic и URL с данными пользователя отклоняются. Эвристический отбор исходников не гарантирует обнаружения каждого неизвестного секрета. --allow-code-upload означает явное согласие на передачу отобранного пакета в Anthropic на условиях выбранного аккаунта. До запуска подтвердите полномочия на передачу.

## Проверьте передачу ревьюеру

Назначенный ревьюер проверяет структуру, типы файлов, права, хеши, соответствие коммита и снимка, хеши политики и ресурсов, завершение сканеров, покрытие Hunter/Verifier и записанное решение.

Манифест не подписан. Проверка не доказывает авторство или неизменность хранения криптографически. Личность ревьюера, одобрение, исключения и принятие риска контролируются вне CommitScope.

```
commitscope verify-review --run /protected/reviews/run-id
```

## Запишите решение человека

Изучите нормализованные материалы и заполните копию reviewer-decision-template.json в защищенной системе решений, указав проверенный хеш манифеста. Исходный шаблон не меняйте: он включен в манифест. Различайте подтвержденную уязвимость, неразрешенную гипотезу и пробел покрытия.

## Исправьте и повторите

Создайте минимальный коммит исправления и выполните контролируемые функциональные проверки и тесты безопасности. Проверьте весь новый коммит в новом каталоге: сканеры, Hunter, Verifier, проверка материалов и разбор человеком. Не перезаписывайте прошлые материалы и не переносите решение на измененный код.

Команды и предпосылки описаны в руководстве CommitScope 2.4.0. Ссылки в репозитории: START-HERE.md, docs/REVIEW-PROCESS.md, docs/SECURITY.md и docs/VERIFICATION.md. Методология не заменяет пентест, не гарантирует безопасность и не доказывает прохождение реальной приемки.